



Web Application Vulnerability Assessment Report

Web Application Security Assessment

Prepared by:
RASANI LAKSHMI CHARANYA

Future Interns Project

Cybersecurity Task 1

1.Introduction

Web applications are frequently targeted by attackers due to misconfigurations and security vulnerabilities. This report documents the security assessment performed on a public demo web application using automated and manual testing tools.

The objective of this assessment is to identify potential security weaknesses and recommend improvements.

OBJECTIVE

The main objective of this assessment is to evaluate the security posture of the selected web application and identify possible vulnerabilities that could impact user data or system integrity.

The assessment focuses on identifying missing security headers and configuration weaknesses.

TOOLS USED

The following tools were used during the assessment:

- **Nmap** – Used for identifying open ports and services running on the target host.
- **OWASP ZAP** – Used for automated web application vulnerability scanning.
- **Browser Developer Tools** – Used for manual inspection of HTTP response headers and verification of findings.

NMAP SCAN RESULT

Command Used: nmap -sV
testphp.vulnweb.com

Description:

Nmap was used to identify active hosts and running services. The scan confirmed that the target is reachable and responsive. No critical open ports were identified during the scan.

MEDIUM RISK VULNERABILITY

Vulnerability Name:

Missing Anti-Clickjacking Header

Risk Level: Medium

Confidence: Medium

CWE ID: 1021

WASC ID: 15

Description:

The application does not include protection against clickjacking attacks. The absence of X-Frame-Options or CSP frame-ancestors allows the website to be embedded within an iframe.

Impact:

Users may be tricked into performing unintended actions by clicking on hidden or malicious overlays.

Solution:

- Configure the server to include either:
- X-Frame-Options: DENY or SAMEORIGIN
- CSP frame-ancestors directive

MEDIUM RISK VULNERABILITY

Vulnerability Name:

Content Security Policy (CSP) Header Not Set

Risk Level: Medium

Confidence: High

CWE ID: 693

WASC ID: 15

Description:

The application does not define a Content Security Policy header. CSP helps protect against Cross-Site Scripting (XSS) and data injection attacks by restricting resource loading.

Impact:

Lack of CSP increases the risk of script injection attacks.

Solution:

Configure the web server to include a proper Content-Security-Policy header.

LOW RISK VULNERABILITY

Vulnerability Name:

X-Powered-By Header Disclosure

Risk Level: Low

Confidence: Medium

CWE ID: 497

WASC ID: 13

Description:

The server reveals backend technology information through the X-Powered-By HTTP response header.

Impact:

Attackers may use this information to identify potential technology-specific vulnerabilities.

Solution:

Disable or remove the X-Powered-By header at the server or application level.

INFORMATIONAL FINDINGS

Timestamp Disclosure – Unix

Timestamp values were observed in server responses. This may expose timing information but does not directly impact security.

Cache-Control Header Review

Cache-control directives were observed and require review to ensure sensitive content is not cached.

BROWSER DEVELOPER TOOLS VERIFICATION

Browser developer tools were used to manually verify HTTP response headers and confirm missing security protections identified by OWASP ZAP.

Nmapscan Result

```
Session Actions Edit View Help
(root@kali)-[/home/kali]
# nmap -sV testphp.vulnweb.com

Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-07 08:12 -0500
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.025s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 52.92 seconds
```

MEDIUM RISK VULNERABILITY

Content Security Policy (CSP) Header Not Set

URL: <http://testphp.vulnweb.com/disclaimer.php>

Risk: Medium

Confidence: High

Parameter:

Attack:

Evidence:

CWE ID: 693

WASC ID: 15

Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)

Alert Reference: 10038-1

Input Vector:

Description:

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Other Info:

Solution:

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Reference:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://www.w3.org/TR/CSP/>

Alert Tags:

Key	Value
OWASP_2021_A05	https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
OWASP_2017_A06	https://owasp.org/www-project-top-ten/2017/A6_2017-Security_Misconfiguration.html
POLICY_QA_STD	
POLICY_PENTEST	
SYSTEMIC	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#systemic

MEDIUM RISK VULNERABILITY

The screenshot shows the ZAP (Zed Attack Proxy) interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled 'Standard Mode'. On the left, the 'Alerts' tab is selected, showing a list of 15 alerts. The alert 'Missing Anti-clickjacking Header (Systemic)' is highlighted. The main pane displays the details of this alert.

Missing Anti-clickjacking Header

URL: <http://testphp.vulnweb.com>
Risk: Medium
Confidence: Medium
Parameter: x-frame-options
Attack:
Evidence:
CWE ID: 1021
WASC ID: 15
Source: Passive (10020 - Anti-clickjacking Header)
Alert Reference: 10020-1
Input Vector:
Description:
The response does not protect against 'Clickjacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Other Info:

Solution:
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Reference:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options>

Alert Tags:

Key	Value
OWASP_2021_A05	https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
POLICY_QA_STD	
POLICY_PENTEST	
CWE-1021	https://cwe.mitre.org/data/definitions/1021.html
SYSTEMIC	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#systemic

LOW RISK VULNERABILITY

The screenshot displays the ZAP (Zed Attack Proxy) interface. The left sidebar shows a list of alerts, with 'Timestamp Disclosure - Unix (Systemic)' selected. The main panel shows the details of this alert.

Timestamp Disclosure - Unix

URL: <https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4>

Risk: Low

Confidence: Low

Parameter:

Attack:

Evidence: 1703946492

CWE ID: 497

WASC ID: 13

Source: Passive (10096 - Timestamp Disclosure)

Input Vector:

Description: A timestamp was disclosed by the application/web server. - Unix

Other Info: 1703946492, which evaluates to: 2023-12-30 09:28:12.

Solution: Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

Reference: <https://cwe.mitre.org/data/definitions/200.html>

Alert Tags:

Key	Value
OWASP_2021_A01	https://owasp.org/Top10/A01_2021-Broken_Access_Control/
OWASP_2017_A03	https://owasp.org/www-project-top-ten/2017/A3_2017-Sensitive_Data_Exposure.html
POLICY_PENTEST	
CWE-497	https://cwe.mitre.org/data/definitions/497.html
SYSTEMIC	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#systemic

INFORMATIONAL FINDINGS

The screenshot shows the Burp Suite interface with the 'Alerts' tab selected. The left sidebar lists various alerts, with 'Re-examine Cache-control Directives' highlighted. The main panel displays the details of this alert.

Re-examine Cache-control Directives

URL: <https://firefox-settings-attachments.cdn.mozilla.net/main-workspace/tracking-protection-lists/e7c79838-8db6-4210-9f08-d827d34e6ba9>

Risk: Informational

Confidence: Low

Parameter: cache-control

Attack:

Evidence: public, max-age=3600

CWE ID: 525

WASC ID: 13

Source: Passive (10015 - Re-examine Cache-control Directives)

Input Vector:

Description:

The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.

Other Info:

Solution:

For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".

Reference:

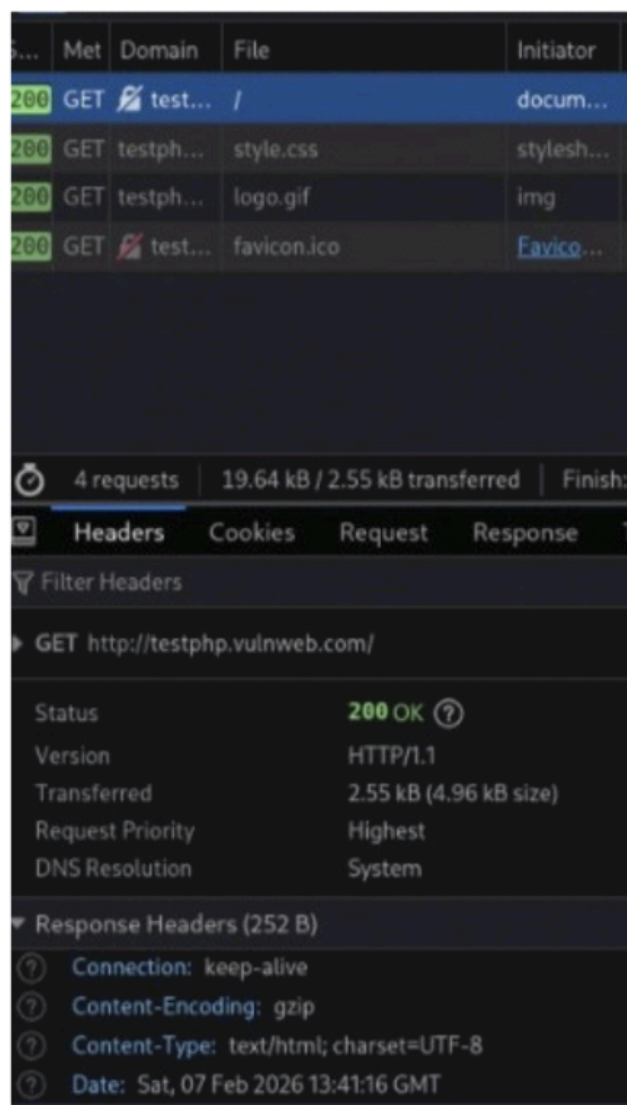
https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control>
<https://grayduck.mn/2021/09/13/cache-control-recommendations/>

Alert Tags:

Key	Value
WSTG-v42-ATHN-06	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing...
CWE-525	https://cwe.mitre.org/data/definitions/525.html
POLICY_PENTEST	
SYSTEMIC	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#systemic

BROWSER DEVELOPER TOOLS

VERIFICATION



CONCLUSION

The assessment identified medium and low-risk security misconfigurations related to missing HTTP security headers. No high-risk vulnerabilities were observed. Implementing recommended security headers will enhance the overall security posture of the application.

DISCLAIMER

This vulnerability assessment report was prepared solely for educational and internship evaluation purposes. The security testing was conducted on a publicly accessible demo website using passive and non-intrusive techniques.

No exploitation, unauthorized access, data modification, or denial-of-service activities were performed during the assessment. The findings documented in this report are based on the tools and methods used at the time of testing and may not represent all possible security vulnerabilities.

The author shall not be held responsible for any misuse of the information contained in this report. This report is intended strictly for academic learning and skill demonstration and must not be used for malicious activities.

REFERENCES

[1] OWASP Foundation, OWASP Top 10 – Security Misconfiguration (A05:2021), 2021.

Available: https://owasp.org/Top10/A05_2021-Security_Misconfiguration/

[2] OWASP Foundation, OWASP Top 10 – Sensitive Data Exposure (A03:2017), 2017.

Available: https://owasp.org/www-project-top-ten/2017/A3_2017-Sensitive_Data_Exposure.html

[3] OWASP ZAP Project, Timestamp Disclosure – Alert Documentation, OWASP.

Available: <https://www.zaproxy.org/docs/alerts/10096/>

[4] OWASP ZAP Project, Missing Anti-clickjacking Header, OWASP.

Available: <https://www.zaproxy.org/docs/alerts/10020/>

[5] OWASP ZAP Project, Content Security Policy (CSP) Header Not Set, OWASP.

Available: <https://www.zaproxy.org/docs/alerts/10038/>

[6] OWASP ZAP Project, X-Content-Type-Options Header Missing, OWASP.

Available: <https://www.zaproxy.org/docs/alerts/10021/>

[7] OWASP ZAP Project, Re-examine Cache-Control Directives, OWASP.

Available: <https://www.zaproxy.org/docs/alerts/10015/>

[8] MITRE Corporation, CWE-1021: Improper Restriction of Rendered UI Layers or Frames.

Available: <https://cwe.mitre.org/data/definitions/1021.html>

[9] MITRE Corporation, CWE-693: Protection Mechanism Failure.

Available: <https://cwe.mitre.org/data/definitions/693.html>

[10] Mozilla Developer Network (MDN), HTTP Header – X-Frame-Options.

Available: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

[11] Mozilla Developer Network (MDN), Content Security Policy (CSP).

Available: <https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>

[12] Mozilla Developer Network (MDN), Cache-Control HTTP Header.

Available: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control>

[13] Nmap Project, Nmap Service and Version Detection.

Available: <https://nmap.org/book/man-version-detection.html>